

Introducción a la ciberseguridad

1. La problemática de la Seguridad TIC.

2.1. Riesgos:

El uso de las TICs ha supuesto un gran avance e importantes mejoras para la vida cotidiana, la comunicación entre personas y los entornos profesionales. Pero también lleva asociados sus riesgos, que son tanto intrínsecos a la propia tecnología, como al (mal) uso que hacemos de ella o a las nuevas posibilidades (para bien o para mal) que se nos abren.

Entre estos riesgos tenemos:

- a. Robo de información (pérdida de confidencialidad y ataques contra la privacidad).
- b. Sabotajes y ataques contra la disponibilidad de los servicios.
- c. Alteración o manipulación de los servicios para que realicen acciones no deseadas.
- d. Acción a distancia.
- e. Anonimato o dificultad para determinar la identidad.
- f. Falsificación de información.

Concretando algo más, podemos apuntar algunos riesgos que nos pueden afectar directamente:

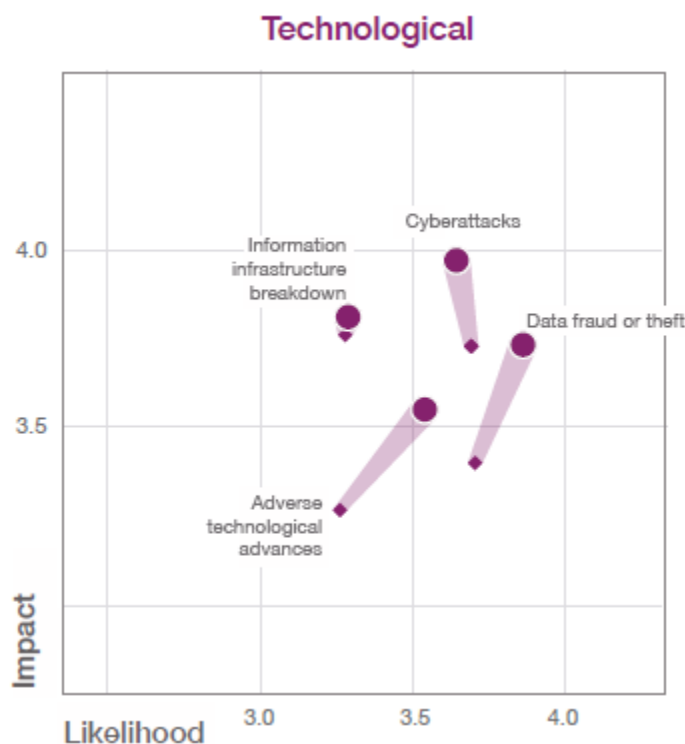
- a. Acceso por parte de un tercero no autorizado a información confidencial (en el ámbito profesional) o privada (en el ámbito personal).
- b. Tratamiento de información personal para un uso distinto al legítimo.
- c. Destrucción de información en nuestro ordenador.
- d. Robo de credenciales de acceso a servicios, para suplantar nuestra identidad tanto en ese como en otros servicios para los que hayamos utilizado las mismas credenciales. Además, el posible atacante ganará así un punto de acceso a nuestra red corporativa y desde ahí puede tratar de acceder a otros equipos y servidores (lo que se denomina “movimiento lateral”). Así, un fallo en nuestras credenciales podría significar el compromiso de otras personas o equipos.
- e. Uso de nuestro equipo (PC) por parte de un tercero malintencionado para actividades delictivas.
- f. Entorpecer el correcto funcionamiento de nuestro ordenador.
- g. Estafas en la compra online de productos o servicios.

E incluso en otro plano que nos afecta como amenaza global (ver informe sobre riesgos globales del World Economic Forum

http://www3.weforum.org/docs/WEF_Global_Risk_Report_2020.pdf), se puede hablar de:

- a. Ciberguerra y soberanía digital de los estados.
- b. Ciberespionaje.
- c. Cibernsabotajes: ataques a infraestructuras críticas.

- d. Ciberterrorismo (ciberyihadismo).
- e. Hacktivismo
- f. Noticias falsas y “hacking de la democracia”.



Para conocer exactamente a qué se refieren estos términos y ampliar la información sobre estos aspectos, una referencia muy interesante es el Informe anual del CCN-CERT sobre hacktivismo y ciberyihadismo (CCN-CERT IA 17-21) al que se puede acceder en <https://www.ccn-cert.cni.es/informes/informes-ccn-cert-publicos/5933-ccn-cert-ia-17-21-informe-anual-2020-hacktivismo-y-ciberyihadismo-1/file.html>

2.2. Términos más comunes (Glosario):

En el mundo de la ciberseguridad se han ido acuñando una serie de términos propios para nombrar fundamentalmente amenazas o técnicas de ataque, que generalmente provienen del inglés y que nos pueden confundir. En este apartado trataremos de definir y explicar algunos de ellos, los más comunes.

- **Malware:** podemos traducirlo como “software o programa malicioso” y se trata de un tipo de software que tiene como objetivo dañar o infiltrarse en un ordenador sin el consentimiento de su propietario.
A su vez nos podemos encontrar distintas categorías de malware en función de la acción maliciosa que realizan:
 - **Gusano:** se propaga de forma muy rápida infectando otros ordenadores que estén conectados a una red.

- o **Troyano:** se instala y ejecuta sin que el usuario del ordenador lo perciba y establece comunicación con un equipo malicioso remoto permitiendo al atacante controlar nuestro equipo.
 - o **Spyware** o “software espía”: recopila información de nuestro ordenador y después la envía a una entidad remota sin nuestro conocimiento.
 - o **Ransomware:** se ejecuta en el equipo infectado y “secuestra” la información del usuario cifrándola, de tal forma que permanece ilegible si no se cuenta con la contraseña de descifrado. Posteriormente, el atacante extorsiona al usuario pidiendo un rescate económico a cambio de esta contraseña para que, supuestamente, pueda recuperar sus datos.
 - o **Criptoware:** de forma inadvertida para el usuario, este malware utiliza la potencia de cálculo de su equipo para el minado de criptomonedas (cryptomining).
-
- **Bug:** error o fallo en un programa que desencadena un resultado indeseado. Generalmente, el malware aprovecha estos bugs o fallos de software para realizar sus acciones maliciosas. Un bug es una vulnerabilidad de un programa.
 - **Exploit:** Secuencia de comandos que aprovecha un bug en un programa para provocar en él un comportamiento indeseado. Dicho de otra forma: el **malware** es un programa que contiene uno o varios **exploits** que aprovechan **bugs** en un programa que tenemos instalado en nuestro ordenador.
 - **Parche o actualización de seguridad:** conjunto de cambios que se aplican a un software o programa para corregir errores de seguridad; son desarrollados por el fabricante del software tras la detección de una vulnerabilidad (bug) en el software y pueden instalarse de forma automática o manual por parte del usuario. La aplicación de un parche hace que nuestro sistema sea inmune de forma permanente a un bug y, por lo tanto, al malware que trata de aprovecharse del mismo.
 - **Antivirus:** programa específicamente diseñado para detectar, bloquear y eliminar malware. El antivirus previene que un malware actúe en nuestro sistema, pero no corrige la vulnerabilidad y, por lo tanto, no nos hace inmunes al malware.
 - **Ingeniería social:** tácticas basadas en el engaño, utilizadas para obtener información y datos de naturaleza sensible, generalmente claves o credenciales, de una persona. Estas técnicas de persuasión suelen valerse de la buena voluntad y falta de precaución de la víctima.
 - **Phishing:** Se trata de un tipo de estafa, que utiliza generalmente el correo electrónico, mediante la cual el estafador suplanta la identidad de una persona de confianza de la víctima, y le solicita información confidencial (contraseñas, datos bancarios, etc.), ya sea directamente en el contenido del propio correo o proporcionándole algún enlace a un sitio web falso. El phishing es actualmente la técnica de ataque más empleada y se basa en la **Ingeniería social**.
 - **Botnet** (red de bots): conjunto de ordenadores (denominados **bots**) controlados remotamente por un atacante que pueden ser utilizados en conjunto para realizar actividades maliciosas como envío de spam, ataques de DDoS, etc. Para incluir un equipo en una botnet, previamente se le ha infectado con un **malware**. Las botnets

se caracterizan por tener un servidor central (C&C, de sus siglas en inglés Command & Control) al que se conectan los bots para enviar información y recibir comandos.

- **Denegación de Servicio (DoS):** tipo de ataque que consiste en saturar con peticiones de servicio a un servidor, hasta que éste no puede atenderlas, provocando su colapso. En el mundo “cyber” es el equivalente a un sabotaje. Un método más avanzado es el ataque de **Denegación de Servicio Distribuido (DDoS)**, mediante el cual las peticiones son enviadas, de forma coordinada entre varios equipos, que pueden estar siendo utilizados para este fin sin el conocimiento de sus legítimos dueños (por ejemplo a través de una *botnet*).
- **Criptografía:** técnica que consiste en cifrar un mensaje, conocido como texto en claro, convirtiéndolo en un mensaje cifrado, que resulta ilegible para todo aquel que no conozca el sistema mediante el cual ha sido cifrado. Existen dos tipos principales de criptografía: por un lado, la conocida como criptografía simétrica, más tradicional, y la criptografía asimétrica que se basa en la utilización de dos claves complementarias: la clave pública y la clave privada. Actualmente, todos aquellos sistemas o comunicaciones que requieren confidencialidad, identificación segura o garantía de autenticidad se basan en la aplicación práctica de la criptografía asimétrica.
- **VPN (red privada virtual):** tecnología de red que permite una conexión virtual punto a punto entre dos equipos usando para la conexión una red pública como es Internet y consiguiendo que esta conexión sea segura gracias al cifrado de la comunicación. Una VPN es un caso práctico de aplicación de la **Criptografía** a las comunicaciones.

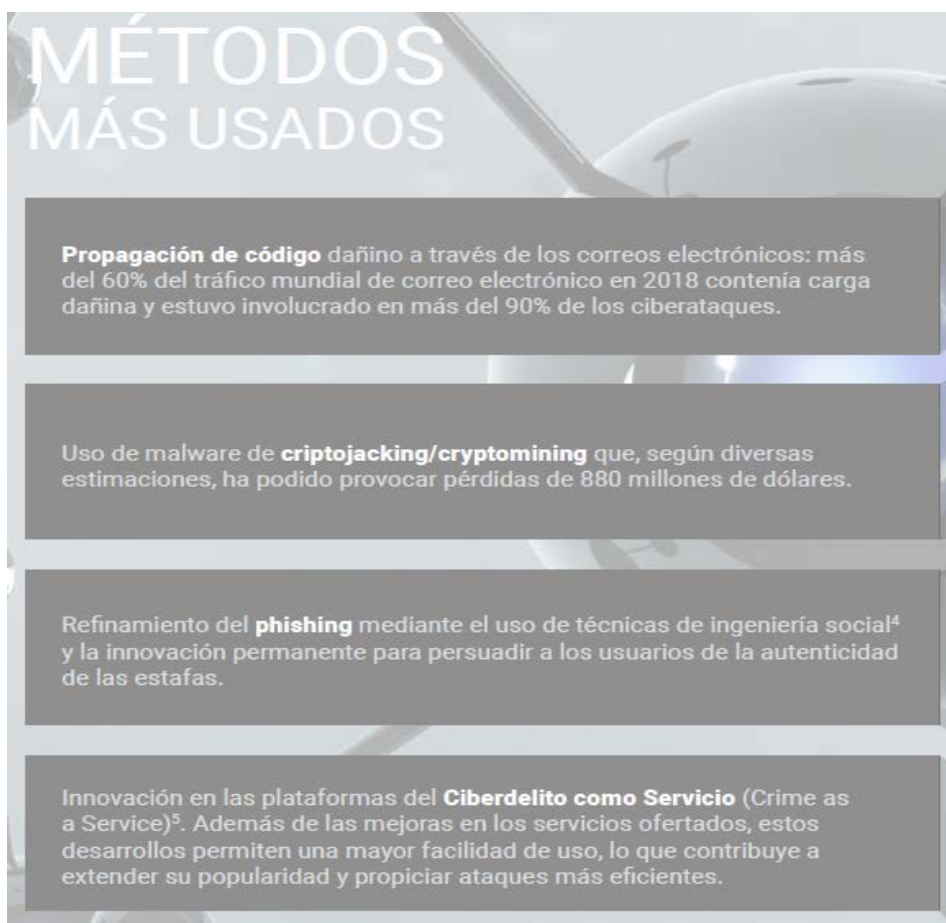
Para una información más exhaustiva, se puede consultar el “Glosario términos de ciberseguridad” del INCIBE (https://www.incibe.es/sites/default/files/contenidos/guias/doc/guia_glosario_ciberseguridad_metad.pdf)

2. Datos y estadísticas sobre incidentes y sus causas y orígenes.

Hay muchas estadísticas sobre ciberseguridad, que tratan de dar una idea del volumen de incidentes, sus tipos, el impacto que generan, las pérdidas, el dinero que invierten las empresas en seguridad e incluso los beneficios económicos que obtienen los atacantes. Nosotros vamos a aportar algunos datos extraídos del informe anual “Ciberamenazas y tendencias” (2020) elaborado por el CCN-CERT, que es el equipo que coordina la respuesta a incidentes en las Administraciones Públicas españolas.

La lectura de este informe es muy recomendable para tener una visión más completa del ámbito y situación actual de la ciberseguridad. Se puede descargar desde <https://www.ccn-cert.cni.es/informes/informes-ccn-cert-publicos/5377-ccn-cert-ia-13-20-ciberamenazas-y-tendencias-edicion-2020/file.html>

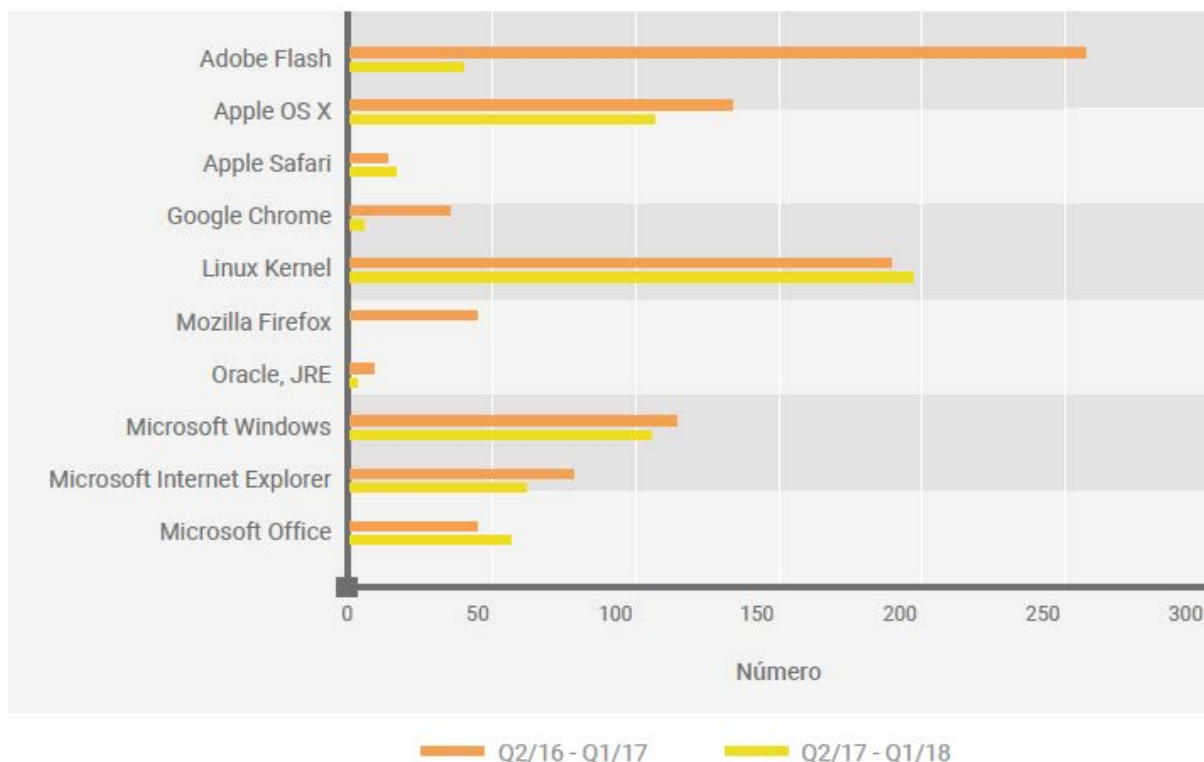
Sobre los métodos más usados:



En relación con el impacto del phishing, se estima que el 90% de las infecciones de malware y el 72% de las fugas de información confidencial en las organizaciones han sido originados por ataques de phishing (fuente: informe ENISA “Threat Landscape Report 2018”).

El volumen diario de correo basura (SPAM) es de 295.620 millones, mientras que el volumen diario de correo legítimo es de unos 51.180 millones; esto significa que el volumen de correo legítimo es el 14,76% del total de correos electrónicos, mientras que el spam supone un 85,23% del total (fuente: informe ENISA “Threat Landscape Report 2018”).

Vulnerabilidades en el software; la siguiente tabla muestra el número de vulnerabilidades descubiertas y resueltas entre 2016 y 2018 del software más comúnmente utilizado; podemos observar la presencia de productos que tienen fama de ser seguros y no sufrir problemas de seguridad.

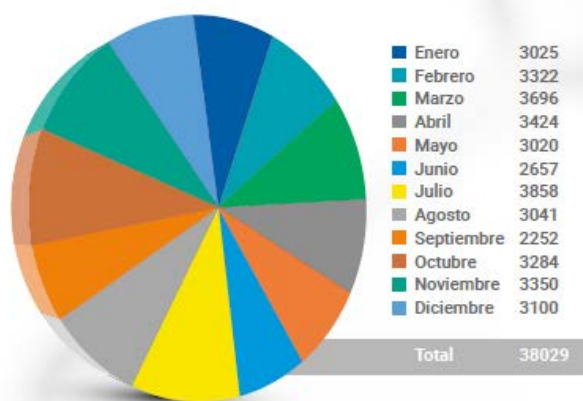


Como complemento a esta tabla, es interesante el dato de que el 79% del código dañino detectado en las organizaciones estaba dirigido a Windows, el 18% a Linux y el 3% a los sistemas Mac. Se observa una tendencia a que los puestos de trabajo sean el objetivo de los ciberatacantes, pues puede suponer un punto de entrada más sencillo a las redes y sistemas de las organizaciones.

En relación con el uso de credenciales robadas por parte de las botnets, se estima que cada botnet lanza unos 300.000 intentos de login (conexión utilizando usuario y contraseña) por hora; Estados Unidos, Rusia y Vietnam son los tres países desde donde se generan más ataques de este tipo (fuente: informe ENISA "Threat Landscape Report 2018").

Sobre el impacto económico de los ciberataques: Según estimaciones de McAfee, el ciberdelito representaría un coste mundial cercano a los 600.000 millones de dólares (o el 0,8% del PIB mundial). No obstante, la actividad delictiva en internet es mucho más amplia que el ciberdelito económico, ya que, esencialmente, todos los elementos de la actividad delictiva humana se han trasladado al ciberespacio.

En 2018, el CCN-CERT ha gestionado un total de 38.192 incidentes de seguridad, lo que ha supuesto un incremento del 43,65% con respecto a 2017.



3. ¿Cómo podemos afrontar estos riesgos?

Una vez que conocemos algo más la problemática a la que nos enfrentamos, no debe cundir el pánico ni el desánimo, y tenemos que ver unas líneas básicas de actuación que nos permitirán minimizar los riesgos y el impacto.

- Los riesgos y amenazas en ciberseguridad no se resuelven SÓLO con tecnología: aunque muchas de las amenazas tienen un carácter tecnológico, otras vienen causadas por un mal uso (intencionado o no) de la tecnología. Las campañas de phishing, basadas en la Ingeniería social, son el principal punto de inicio de un ciberataque; aunque se aplican “soluciones tecnológicas” (antivirus, filtros anti-phishing en los servidores de correo), estas herramientas pueden no filtrar correo malicioso que esté bien elaborado; queda a criterio del usuario, finalmente, determinar si ejecuta o no la acción que le propone un correo sospechoso.
- No es necesario ser un experto en tecnología o adquirir un conocimiento avanzado del mundo de la informática para mantener un cierto grado de seguridad en nuestro ordenador y en nuestras comunicaciones. Con la aplicación de un conjunto sencillo y reducido de buenas prácticas evitaremos muchos de los riesgos.
- Varias líneas de defensa o defensa en profundidad. No existe una solución única que resuelva o elimine un riesgo en su totalidad. Debido a que en el “ciber-mundo” intervienen muy distintos agentes (ordenadores, programas, redes, mecanismos de gestión de identidad y autenticación, información, empresas, personas, etc.) se deben aplicar medidas que se complementen y que traten de atajar una amenaza en los distintos activos a los que pueda afectar. Por ejemplo, contra el malware se

pueden aplicar medidas en el ordenador (antivirus y parches de seguridad), en la red (impidiendo la descarga de ficheros maliciosos) o en el usuario (concienciándolo para que no descargue o ejecute programas de procedencia sospechosa); si una de esas líneas de defensa falla, la siguiente podrá parar, al menos en parte, la amenaza.

- **Comunicación:** en ciberseguridad es muy importante compartir información, para poder conocer un incidente y resolverlo. La comunicación debe darse tanto entre los agentes que tienen que resolver un incidente (equipos técnicos de ciberseguridad), como entre la víctima y el equipo de técnicos que debe resolver el incidente. Colaboración y notificación.
- **Concienciación:** como consecuencia de todos los puntos anteriores. No se puede pretender que el usuario de un ordenador tenga unos conocimientos avanzados de tecnología; y además no es necesario. Simplemente debe ser consciente de los riesgos de un mal uso y tener herramientas y capacidades que le permitan de forma sencilla, evitarlos o minimizar su impacto.

En resumen, es muy importante tener en cuenta que la seguridad no es simplemente una tecnología, sino que es una forma de pensar y actuar que debe estar presente en todos los elementos que actúan en un sistema de información, incluido el componente humano.

4. Desmontando algunos mitos.

Hay una serie de ideas y comentarios que se oyen muy a menudo y que sería conveniente aclarar:

- ***“No me importa demasiado que se me instale algún malware; no tengo información de gran interés en mi ordenador”:*** siempre hay información personal interesante para el ciberdelincuente, aunque para nosotros pueda no tener mucha relevancia. A partir de esta información se puede, entre otras cosas, obtener nuestro perfil, suplantar nuestra identidad, acceder a nuestros contactos, o bien, como ya se ha dicho, acceder a otros recursos de nuestra organización y, por lo tanto, poner nuestro sistema en situación de compromiso. Por lo tanto, siempre será mejor prevenir y evitar la instalación de malware en nuestro equipo.
- ***“Tenemos unos sistemas completamente seguros”:*** no existe la seguridad completa; la seguridad es siempre un compromiso entre las medidas que podemos aplicar y los riesgos que debemos asumir. Los riesgos se deben minimizar y aceptar, pero no podemos suprimirlos del todo.
- ***“Los atacantes (hackers) son gente muy inteligente y capacitada”:*** dentro del mundo de la ciberdelincuencia nos encontramos todo tipo de perfiles: desde profesionales con alto nivel de cualificación trabajando para organizaciones criminales que manejan un presupuesto superior, por ejemplo, al de nuestra universidad, hasta gente sin apenas conocimientos técnicos que se limitan a repetir patrones de ataque

o recetas que están publicadas en Internet. Los primeros sí que generan ataques realmente sofisticados, pero hacen una selección muy cuidada de sus objetivos, pues sólo atacarán a aquellos que les suponga una ganancia económica o política relevante. Los segundos son los más habituales y no hacen discriminación en cuanto a sus objetivos, pero también son los más sencillos de detectar y de prevenir.

- *“No hay mucha motivación de los atacantes para atacar equipos de uso particular”*: esto también es falso; las credenciales robadas y equipos comprometidos en redes de bots (botnets) se van acumulando y se venden o alquilan “al peso” en el “mercado negro” (Dark web) para que otros agentes maliciosos las utilicen para ataques masivos. Es lo que se denomina “Cybercrime as a Service” (CaaS).
- *“Esto de la ciberseguridad no va conmigo, soy demasiado torpe para estas cosas”*. El objetivo de estas sesiones de formación es proporcionaros ideas y herramientas sencillas para que tengáis más confianza en el uso seguro de las TIC.

5. Buenas prácticas básicas:

En concreto, y de cara a nuestro día a día, aquí van una serie de consejos básicos que nos evitarán muchos problemas y sobre los que iremos profundizando a lo largo de futuras sesiones.

En esta lista se ha tratado de abordar lo que, según nuestra experiencia, son las situaciones y problemas más típicos y las herramientas o decisiones que debemos adoptar para evitar los riesgos:

1. No abrir ningún enlace o fichero adjunto en los correos que consideremos sospechosos; y ante cualquier sospecha, preguntar al remitente (si se trata de alguien conocido) o al Servicio de Informática de la Universidad. Con esto evitaremos ser víctimas de phishing o que se nos instale un malware (en el caso de los ficheros adjuntos).
2. Mantener siempre actualizado nuestro sistema operativo (sea el que sea: Windows, IOS, Android, Linux, etc.) y el resto de programas, fundamentalmente el navegador. Con esto nos evitaremos la ejecución de malware en nuestro equipo.
3. Utilizar contraseñas fuertes (que sean difíciles de adivinar) y cambiarlas regularmente o, al menos, cuando se tengan sospechas de que pueden haber sido comprometidas. Así evitaremos que suplanten nuestra identidad, el acceso de terceros a información privada o confidencial, robos en cuentas bancarias, etc. Las contraseñas deben de ser secretas y únicas, no debemos anotarlas, compartirlas o reutilizarlas.
4. No utilizar las credenciales de acceso corporativas en aplicaciones de uso personal; no dar nuestras contraseñas (o cualquier tipo de información sensible) a través de medios inseguros (wifis abiertas, servidores web inseguros, etc.).
5. No instalar aplicaciones de origen desconocido; pueden (suelen) contener malware “incrustado”.
6. Tener instalado y activado un antivirus que esté debidamente actualizado.

7. Usar herramientas de borrado seguro cuando se quiera eliminar información sensible o cuando se vaya a desechar un equipo. Así evitaremos la filtración de información privada o confidencial.
8. Ser cautos con los dispositivos externos de memoria (USB) que conectamos a nuestro equipo.
9. Hacer copias de seguridad de nuestra información sensible.
10. En caso de sospechar que se ha sido víctima de un ataque de seguridad comunicarlo a los técnicos que puedan resolverlo o a las personas de tu entorno que puedan ayudarte.

También tenéis otros recursos informativos interesantes en cuanto a buenas prácticas básicas en:

- INCIBE:
 - o Línea 017 y casos prácticos reales: <https://www.incibe.es/linea-de-ayuda-en-ciberseguridad>
 - o Guías de ciberseguridad: <https://www.osi.es/es/guias-ciberseguridad>
- Principios y recomendaciones básicas en Ciberseguridad (CCN-CERT): <https://www.ccn-cert.cni.es/informes/informes-de-buenas-practicas-bp/2473-ccn-cert-bp-01-principios-y-recomendaciones-basicas-en-ciberseguridad/file.html>

6. Normativa de Seguridad UPCT:

Según se establece en el Esquema Nacional de Seguridad (RD 3/2010), todas las Administraciones Públicas deben disponer de una normativa de seguridad; la última versión de la Normativa de Seguridad de la UPCT se aprobó en Consejo de Gobierno el 17 de diciembre de 2020.

Se puede consultar en: <https://lex.upct.es/download/cfa14391-2f66-4add-88f2-5eba53c10305>

En su preámbulo, se establece que:

“Los usuarios de la red y de los servicios informáticos de la UPCT deben mantener la integridad de los recursos basados en los sistemas de información, evitar actividades destinadas a obtener accesos no autorizados o suplantación de identidad, respetar los derechos del resto de usuarios, no acaparar los recursos compartidos con el resto de usuarios, respetar las políticas de licencias de software y colaborar en evitar, identificar y resolver los incidentes de seguridad por los que se puedan ver afectados.”

A continuación destacamos algunos extractos con las ideas más relevantes de cara a esta formación:

- Sobre las **cuentas de usuario** (Art. 3):
 1. Los usuarios son responsables de la custodia de sus credenciales.
 2. Los usuarios no deben revelar o entregar, bajo ningún concepto, sus credenciales a otra persona.

3. Si un usuario tiene sospechas de que sus credenciales están siendo utilizadas por otra persona o, de forma accidental, la ha proporcionado por un medio indebido, debe cambiarla inmediatamente y proceder a comunicar a la Unidad de Informática la correspondiente incidencia de seguridad.
 4. Instrucciones sobre contraseñas, que marcarán las directrices que deben seguir para ser suficientemente seguras: longitud, formato, restricciones y periodo de caducidad.
- Sobre el **uso de los equipos** (Art. 4):
 1. El usuario de equipos informáticos debe procurarse los conocimientos imprescindibles para el manejo seguro y buen uso de los sistemas de información. Se debe limitar en la medida de lo posible la capacidad de que el usuario pueda realizar cambios en su configuración (seguridad por defecto y mínima funcionalidad).
 2. Aspectos mínimos de seguridad que deben ser tenidos en cuenta por todos los usuarios:
 - Actualizaciones del Sistema Operativo.
 - Antivirus: Todos los equipos deben tener activo y actualizado un software antivirus o de protección del equipo, preferentemente facilitado bajo licencia corporativa por la UPCT.
 - Inventariado y trazabilidad: los equipos deben tener instalado un software que permita disponer de un inventario automatizado y la monitorización de configuraciones y eventos básicos del sistema.
 - Protección/bloqueo del equipo por inactividad: El equipo o puesto de trabajo se deberá configurar para que se bloquee al cabo de un tiempo de inactividad.
 - Servicios o aplicaciones no necesarias: Si una aplicación no es necesaria para el trabajo del usuario del equipo, no debe estar instalada.
 - Copias de seguridad de la información.
 3. La UPCT pondrá a disposición de los usuarios herramientas que les facilitarán estos requerimientos.
 4. Ejemplos de usos indebidos (art. 11).
 - Gestión y **acceso a la Red de la UPCT** (Art. 5):
 1. La red cableada es responsabilidad de la Unidad de Informática; todos los equipos que se conectan a la red deben recibir una dirección IP y un nombre de red asignados por la Unidad de Informática.
 2. Protección de accesos remotos: VPN y equipos remotos debidamente seguros.
 - Sobre el uso del **correo electrónico** (Art. 7).
 - **Datos personales** y confidencialidad (art. 8):

1. Todo usuario que pudiera tener acceso a datos de carácter personal, está obligado a guardar la confidencialidad debida sobre los mismos.
 2. Cuando así se requiera, los datos y la información sensible, confidencial o protegida, deberán ser eliminados de forma segura.
 3. Se prohíbe alojar información confidencial propia de la UPCT en servidores externos en “la nube” que no haya ofrecido la institución, en particular cuando se trate de datos de carácter personal. (art. 10)
- Sobre incidentes de seguridad (Art. 13):
 - o Cuando un usuario detecte cualquier anomalía o incidencia de seguridad que pueda comprometer el buen uso y funcionamiento de los Sistemas de Información de la Universidad o su imagen, deberá informar inmediatamente a la Unidad de Informática (a través del Soporte a usuarios).
 - Monitorización (Art. 14):
 1. La UPCT, cumpliendo en todo momento los requisitos que al efecto establece la legislación vigente:
 - a. Revisará periódicamente el estado de los equipos, el software instalado, los dispositivos y redes de comunicaciones de su responsabilidad.
 - b. Monitorizará los accesos a la información y a los servicios on-line que proporciona a sus usuarios.
 - c. Auditará la seguridad de las credenciales y aplicaciones.